

# Ceremony Meets Usability: An HCI Lens on Authentication

**Other Conference Item****Author(s):**

Schöni, Lorin 

**Publication date:**

2026

**Permanent link:**

<https://doi.org/https://doi.org/10.3929/ethz-c-000797342>

**Rights / license:**

[Creative Commons Attribution 4.0 International](#)

# Ceremony Meets Usability: An HCI Lens on Authentication

Lorin Schöni  
lorin.schoeni@gess.ethz.ch  
ETH Zurich  
Zurich, Switzerland

## Abstract

Passkeys are rapidly moving from niche to mainstream as a phishing-resistant alternative to passwords. Yet, they expose gaps in recovery and cross-device flows, while attackers exploit human fatigue and AI-driven deception to bypass these cryptographic improvements. To address these challenges, we revisit two landmarks in usable security: *Why Johnny Can't Encrypt* (1999) and *Ceremony Design and Analysis* (2007). Our synthesis links *task-level usability* (can users do it?) with *ceremony-level robustness* (is the context safe?), offering a lens for design and evaluation beyond protocol correctness. We conclude by outlining directions for treating authentication flows as familiar HCI patterns, focusing on clarity, consistency, and resilience, so that authentication becomes both usable and hard to misuse.

## Keywords

usable security, authentication, passkeys, security ceremonies

## 1 Introduction

WebAuthn passkeys promise a passwordless, phishing-resistant future, yet their rollout reveals cracks in the experience. Variation in registration, recovery, and cross-device use creates confusion [5, 20], while attackers have shifted tactics to exploit human fatigue rather than encryption. This is evident in the rise of prompt bombing [18, 25], as well as AI-driven phishing and adversarial automation [3, 15]. These attacks target the *ceremony* of authentication, not the protocol.

Usable security research has long recognised that cryptographic correctness is insufficient if users cannot reliably enact the required tasks [10, 14]. Whitten and Tygar's *Why Johnny Can't Encrypt* demonstrated, via an evaluation of PGP 5.0, that apparently "good" interfaces still failed to support novices in performing secure email operations [26]. They argued that security-critical interaction demands a distinct usability standard. Ellison's *Ceremony Design and Analysis* extended this perspective by showing that security protocols are not just technical steps but include people, interfaces, and even physical or social actions [12]. These extra steps, often called "out-of-band" (e.g., confirming a code via SMS or showing an ID), are part of the ceremony and require deliberate design.

Building on these foundations, we revisit *Johnny* and *ceremony* design together to address today's authentication challenges. Rather than proposing a rigid new framework, our goal is to suggest a shift in perspective. By looking at authentication through both of these classic lenses simultaneously, we hope to give designers and

researchers a useful heuristic for talking about why modern flows like passkeys sometimes fail in practice.

## 2 Two lenses to revisit

*Johnny's security usability standard.* *Johnny* established that conventional usability heuristics do not suffice when mistakes have security consequences: the unit of analysis must be the *security task* (e.g., sign-then-encrypt with correct keys), the *mental models* (keys, identities, trust), and the *error surface* where slips lead to a breach [26]. This insight is still relevant for automation. Passkeys shift work from users to authenticators and relying parties, but still leave users with moments of judgement (choice of device, nearby-device approval, account recovery, attestation choices, and consent to risky fallbacks) where misunderstanding is costly [5, 20].

*Ceremony design, not protocol fragments.* Ellison's ceremony concept insists that human actors, UI channels, and social exchanges are *in band* for analysis [12]. Modern authentication involves actors (user, device, authenticator), channels (prompts, QR codes, recovery flows), and trust assumptions (metadata). Recent work on user-centred ceremony design reinforces this need for structured socio-technical modelling [6, 13].

*Combining the lenses: towards ceremony-aware usability.* Taken together, these lenses suggest security design must operate on two planes: *task-level comprehensibility* and *ceremony-level robustness* [22]. *Johnny* highlights learnable paths through security-critical tasks. Ellison shows these tasks sit within ceremonies whose integrity depends on trust and channels. Combined, they offer a conceptual foundation for authentication that anticipates failure modes such as MFA fatigue or recovery exploits [8].

## 3 Contemporary landscape through the two lenses

We now highlight specific challenges where these lenses reveal why current solutions fall short.

### 3.1 Passkeys: promise and ceremony gaps

Passkeys provide phishing-resistant authentication by binding public-key credentials to a relying party. While they effectively stop credential stuffing, they introduce new mental model gaps regarding recovery, delegation, and cross-system portability [5, 20]. Recent audits underline this tension: passkeys hold clear security promise, yet implementations reveal uneven patterns across sites and sectors that leave users confused [20, 23].

Seen through *Johnny*, the critical issue is the task model: how do users understand keys that sync across some devices but not others? A *ceremony* lens, in turn, interrogates the context: are the trust checks visible and resilient when a phone is lost or a vendor changes? Updated design guidance seeks to standardise these flows [1, 2], yet insights from industry suggest that without clear ceremony design



This work is licensed under a Creative Commons Attribution 4.0 International License.  
AlpCHI 2026, Revisiting HCI Research  
© 2026 Copyright held by the owner/author(s).  
<https://doi.org/10.3929/ethz-c-000797342>

involving phased rollouts and user involvement, adoption remains fragile [4].

### 3.2 MFA fatigue as ceremony failure

“Prompt bombing” exploits the approval *ceremony* rather than any cryptographic weakness: repeated, interruptive prompts shift the user’s goal from validation to stopping the noise [18, 25]. Effective mitigations (e.g., number matching or contextual prompts) are therefore ceremony-level redesigns. They must bind context to action while respecting the user’s compliance budget, ensuring that users validate the login source rather than blindly clicking “Approve” just to clear the screen [8, 18, 25].

### 3.3 Indicators in an era of AI-assisted deception

*The Emperor’s New Security Indicators* showed that users often overlook passive cues (like HTTPS locks) and that behavioural stakes matter [24]. With AI-assisted phishing generating polished, context-aware threats, the salience and timing of indicators become even more critical. A ceremony-first stance argues that we cannot rely on users noticing subtle changes in the browser’s UI, such as the address bar. Instead, decisive cues (such as the requesting device, location, or transaction scope) must be bound directly into the approval step, aligning the security check with the user’s immediate goal [16, 24].

## 4 Opportunities for HCI

Rather than prescribing a rigid set of UI guidelines, we see our synthesis pointing toward three open opportunities for the HCI community to explore:

1. *Evaluate ecosystem usability over isolated tasks.* Authentication is often treated as an isolated security hurdle, but users experience it as a broader ecosystem. If two different services implement passkeys with entirely different functionality, such as conflicting recovery methods, the resulting mental model clash degrades the usability of *both* systems from the user’s perspective. This highlights a critical gap: we cannot accurately test usability in isolation. What if we approached authentication as a cohesive, ecosystem-wide interaction sequence? By establishing consistent UX patterns across platforms, designers can evaluate usability and trust cues in the context of the user’s experiences across services, rather than just within the vacuum of a single app.

2. *Prioritise security-critical choice points.* User errors in authentication do not happen randomly. As we see with MFA fatigue and early passkey adoption, mistakes usually cluster around specific, high-friction moments like cross-device migration or unexpected approval prompts. A major opportunity lies in redesigning these exact choice points. If interfaces can clearly show users the context of their action, such as verifying exactly who is requesting access, developers can help them make secure decisions without causing cognitive overload.

3. *Shift from panic to rehearsable recovery.* Perhaps the most pressing challenge is account recovery, which is currently experienced as a high-stress, panic-driven exception. Shifting this towards a rehearsable moment, much like a digital fire drill, could transform

these fragile edge cases into familiar routines. This enables users to reveal weaknesses and build trust before an actual crisis hits.

## 5 Broader Implications

While our focus has been on usable security, the synthesis of task-level usability and ceremony-level robustness also resonates with broader HCI concerns:

*The ceremony as an interaction unit.* HCI already possesses frameworks for understanding complex, multi-device tasks, such as distributed cognition and activity theory [17, 19]. By applying these directly to authentication, we can shift our focus from isolated UI screens to the entire ecosystem of devices, people, and environmental cues, making the ceremony structure our primary design concern.

*Designing for adversarial conditions.* Traditional HCI optimises for efficiency and satisfaction under benign conditions. Security ceremonies, however, must survive active deception, interruption, and uncertainty. Therefore, our evaluation metrics must evolve beyond simple time-on-task. We need to measure a system’s robustness against misleading cues, its ability to prevent unsafe shortcuts, and the user’s actual comprehension of risk [7, 21].

*Calibrating trust against AI deception.* As attackers increasingly use AI to generate highly convincing phishing campaigns, users need better ways to gauge whether a prompt is genuine. Borrowing from Human-AI Interaction (HAI), systems should provide situated cues exactly at the point of action [9, 11]. This means placing clear, verifiable context directly in the approval step to prevent both blind trust and alert fatigue.

## 6 Scope and Conclusion

Rather than prescribing strict UI guidelines, our goal is to reframe authentication as an ecosystem-wide interaction design challenge. The rollout of passkeys and the rise of MFA fatigue prove that protocol correctness alone is insufficient when human decisions are under attack. By merging task-level usability with ceremony-level robustness [12, 26], we can identify exactly where design effort is most needed.

Prioritising ecosystem consistency, clear context at critical choice points, and rehearsable recovery will help ensure that modern authentication is not only secure on paper, but also highly resilient in practice. Ultimately, as adversaries increasingly leverage automation to probe for weaknesses and support structures themselves become automated, the robustness of these fallback and recovery flows will influence the security of the entire system.

## References

- [1] 2024. Design Guidelines for Passkeys - Windows Apps. <https://learn.microsoft.com/en-us/windows/apps/develop/security/design>
- [2] 2024. FIDO Alliance Design Guidelines for Passkeys. <https://fidoalliance.org/new-design-guidelines-optimizing-user-sign-in-experience-with-passkeys/>
- [3] 2025. Cybersecurity Implications of AI: Pulse Report. <https://ismg.io/resource/cybersecurity-implications-of-ai-pulse-report-2025/>
- [4] 2025. Passkeys for Enterprise Report from FIDO. <https://www.biometricupdate.com/202503/passkeys-for-enterprise-report-from-fido-says-adoption-is-growing>
- [5] 2025. WebAuthn and Passkeys Primer. <https://www.webauthn.me/passkeys>
- [6] A. Alatawi et al. 2023. SoK: An Analysis of End-to-End Encryption and Authentication Ceremonies. In *ACM CCS*. <https://doi.org/10.1145/3558482.3581773>

- [7] Saleema Amershi and et al. 2019. Guidelines for Human-AI Interaction. In *Proceedings of CHI*. 1–13. doi:10.1145/3290605.3300233
- [8] A. Beatelement, M. A. Sasse, and M. Wonham. 2008. The Compliance Budget: Managing Security Behaviour in Organisations. In *NSPW*. <https://doi.org/10.1145/1595676.1595684>
- [9] Andrea Bussone and et al. 2015. The Role of Explanations on Trust and Reliance in Clinical Decision Support Systems. *International Journal of Human-Computer Studies* 72, 12 (2015), 941–953. doi:10.1016/j.ijhcs.2014.09.002
- [10] F. Di Nocera et al. 2023. Usable Security: A Systematic Literature Review. *Information* 14, 12 (2023), 641. <https://doi.org/10.3390/info14120641>
- [11] Upol Ehsan and Mark O. Riedl. 2020. Human-Centered Explainable AI: Towards a Research Agenda. In *Proceedings of CHI Workshop on Human-Centered XAI*. [https://doi.org/10.1007/978-3-030-60117-1\\_33](https://doi.org/10.1007/978-3-030-60117-1_33)
- [12] Carl Ellison. 2007. Ceremony Design and Analysis. *IACR ePrint*. <https://eprint.iacr.org/2007/399>
- [13] M. Fassl et al. 2021. Exploring User-Centered Security Design for Usable Authentication Ceremonies. In *CHI Conference on Human Factors in Computing Systems*. <https://doi.org/10.1145/3411764.3445164>
- [14] Steven Furnell. 2024. Usable Cybersecurity: a Contradiction in Terms? *Interacting with Computers* 36, 1 (2024), 3–20. <https://doi.org/10.1093/iwc/iwad035>
- [15] M. Hashmi et al. 2024. Securing Tomorrow: A Comprehensive Survey on AI and Information Security. *Journal of Ambient Intelligence and Humanized Computing* (2024). <https://doi.org/10.1007/s43681-024-00529-z>
- [16] F. Heiding, B. Schneier, A. Vishwanath, and J. Bernstein. 2023. Devising and Detecting Phishing: Large Language Models vs. Smaller Human Models. *Black Hat USA* whitepaper. <https://doi.org/10.48550/arXiv.2308.12287>
- [17] James Hollan, Edwin Hutchins, and David Kirsh. 2000. Distributed Cognition: Toward a New Foundation for Human-Computer Interaction Research. *ACM Transactions on Computer-Human Interaction* 7, 2 (2000), 174–196. doi:10.1145/353485.353487
- [18] D. James. 2023. Beating MFA Fatigue: Why Hackers Have Resorted to Prompt Bombing. *CPO Magazine*. <https://www.cpomagazine.com/cyber-security/ beating-mfa-fatigue-why-hackers-have-resorted-to-prompt-bombing/>
- [19] Victor Kaptelinin and Bonnie Nardi. 2012. *Activity Theory in HCI: Fundamentals and Reflections*. Morgan & Claypool. <https://dl.acm.org/doi/10.5555/2361921>
- [20] A. Matzen et al. 2025. Challenges and Potential Improvements for Passkey Adoption—A Literature Review with a User-Centric Perspective. *Applied Sciences* 15, 8 (2025), 4414. <https://doi.org/10.3390/app15084414>
- [21] Donald A. Norman. 2013. *The Design of Everyday Things (Revised and Expanded Edition)*. Basic Books.
- [22] A. Orloff and G. Martius. 2025. Meta-Science in Usable Security and Privacy and HCI. <https://doi.org/10.1145/3706598.3714022>
- [23] B. Ramat, D. Kartchner, and K. Seamons. 2025. A Systematic Analysis of the Passkey User Experience (poster abstract). *USENIX SOUPS*. [https://www.usenix.org/system/files/soups2025\\_poster46\\_abstract-ramat\\_v2.pdf](https://www.usenix.org/system/files/soups2025_poster46_abstract-ramat_v2.pdf)
- [24] Stuart E. Schechter, Rachna Dhamija, Andy Ozment, and Ian Fischer. 2007. The Emperor’s New Security Indicators. In *IEEE Symposium on Security and Privacy*. <https://doi.org/10.1109/SP.2007.35>
- [25] University of Chicago Information Security. 2024. MFA Fatigue Attacks: What to Watch For and What To Do. <https://security.uchicago.edu/2024/10/01/mfa-fatigue-attacks/>
- [26] Alma Whitten and J. D. Tygar. 1999. Why Johnny Can’t Encrypt: A Usability Evaluation of PGP 5.0. In *USENIX Security Symposium*. <https://www.usenix.org/conference/8th-usenix-security-symposium/why-johnny-cant-encrypt-usability-evaluation-pgp-50>